



Instituto Profesional **Los Leones**

“Informe caso Ransomware e Identificación de Activos”

Integrantes:

Nicolás Vega

Sebastian Paz

Roberto Ovalle

Curso: Gestión de Riesgo Informático

Profesor: Patricio Jofré

Fecha Entrega: 28/05/2025

Índice

- 1. Introducción del caso**
- 2. Observaciones**
- 3. Documentación**
- 4. Plan Preventivo ante futuros ataques**
- 5. Aplicación ISO 27001**

Introducción del caso

El día 28/05/2025 a las 01:27 se generó un ransomware el cual afectó a 3 equipos y al servidor de la organización. Este ransomware comenzó desde uno de los 3 equipos comenzando la infección desde la carpeta Finanzas, continuando por cada carpeta y posteriormente dirigiéndose a los demás equipos de la organización. los cuales son ingeniería y rrhh. En este informe de accidente mostraremos con evidencia el paso a paso de cómo fueron afectados los departamentos y el servidor.

Realizaremos un plan preventivo sobre ataques de ransomware futuros, para así poder mantener la información segura, monitoreamos las copias de seguridad de la nube o en discos controlados, se mejorarán los controles de acceso en los privilegios mínimos. este ataque se incluirá en el plan de mejora continua.

Observaciones

Durante el ataque el equipo se encargó de monitorear lo que pasaba en los equipos y en el servidor mientras el ransomware infecta y encriptaba toda la información disponible.

- El ransomware se ejecutó manualmente e infectó también el servidor
- Los computadores estaban conectados a un servidor el cual almacena la información, archivos y documentos a los cuales los computadores pueden acceder mediante carpetas compartidas en la red de la empresa
- Se crea un archivo de texto el cual posee instrucciones sobre lo sucedido.
- Este encripto rápidamente los archivos y pidió rescate para que estos no sean publicados.
- Este abre la consola de comandos de win32 del servidor, el cual mostró el mensaje “Actualizando Directiva...”

Documentación

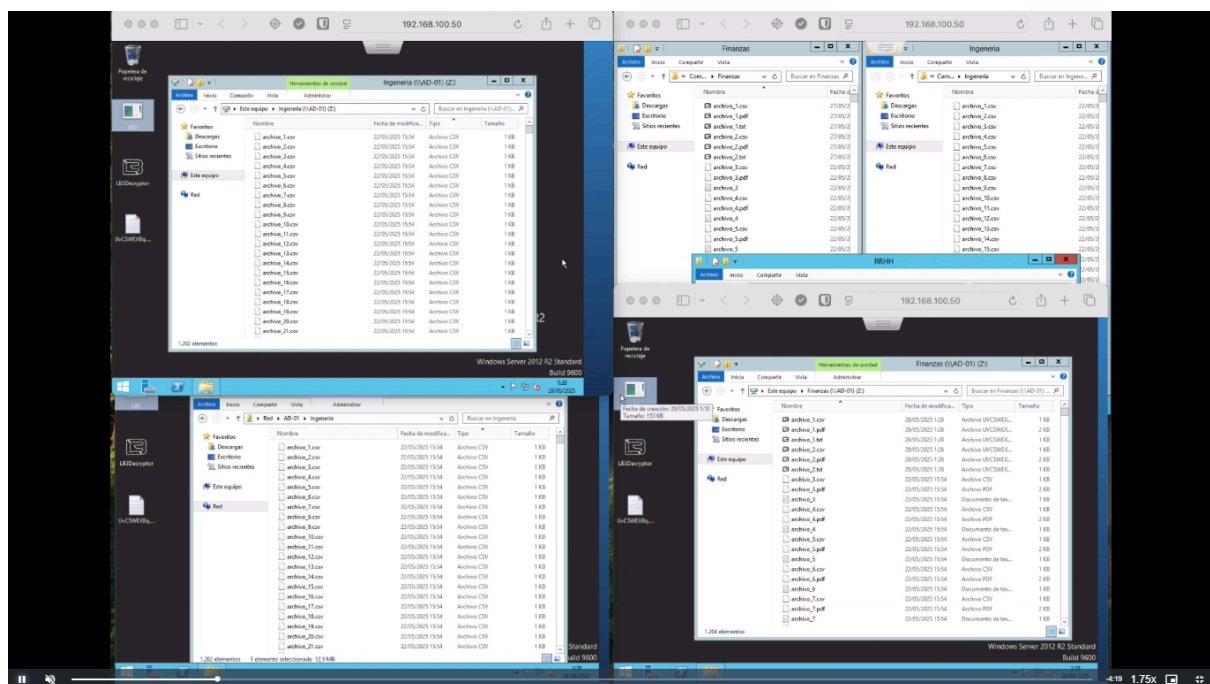
El día 28/05/26 a la 1:27 Am un empleado de la empresa fue engañado y ejecuto el programa que descargó de manera externa sin saber que este tenía intenciones maliciosas el cual resultó ser un Ransomware que se propagó rápidamente al servidor mediante las carpetas compartidas de la Red interna de la empresa, infectando todos los equipos y a su vez secuestrado la información confidencial y delicada de la empresa para posteriormente encriptarla y haciendo amenaza de publicar dicha información si no se paga un rescate, los hechos sucedieron de la siguiente manera, todo el mismo día:

The screenshot displays the VirusTotal web interface for a file analysis. The file's SHA-256 hash is 83d0de35513d39b50df71a53633d709e8b6cadf87e92a7f30a538cb0c09e60ee. The file is identified as 'patched_all_sections.exe' with a size of 147.21 KB and was last analyzed 4 hours ago. A community score of 26/71 is shown, indicating that 26 out of 71 security vendors flagged the file as malicious. The file is categorized as a ransomware lockbit, with threat categories including ransomware and trojan. The security vendors' analysis table shows detections from AliCloud, Avast, Bkav Pro, Arctic Wolf, AVG, and ClamAV, all identifying the file as ransomware. The interface also includes a 'Join our Community' section and a 'Show less' link for the YARA signature match.

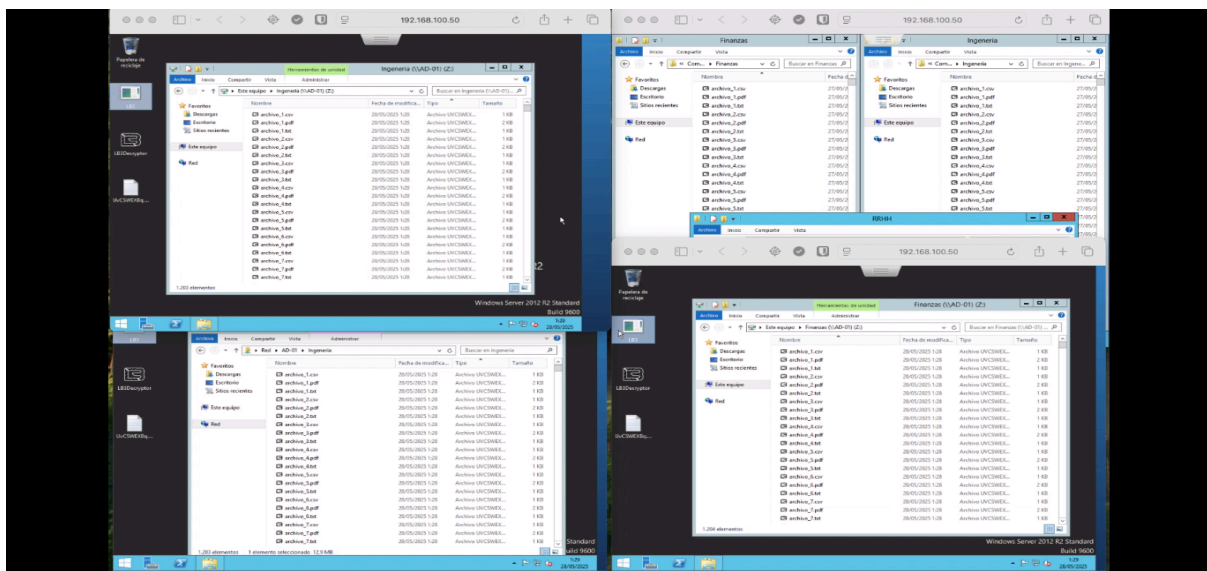
Security vendors' analysis	Do you want to automate checks?		
AliCloud	RansomWare:Win/Lockbit.xiglab	Arctic Wolf	Unsafe
Avast	Win32:Evo-gen [Trj]	AVG	Win32:Evo-gen [Trj]
Bkav Pro	W32:AlDetectMalware	ClamAV	Win.Ransomware.BlackMatter-9970818-0

A la 1:27 Am del día 28/05/25 un empleado abrió un ejecutable el cual era un archivo malicioso el cual contenía un ransomware

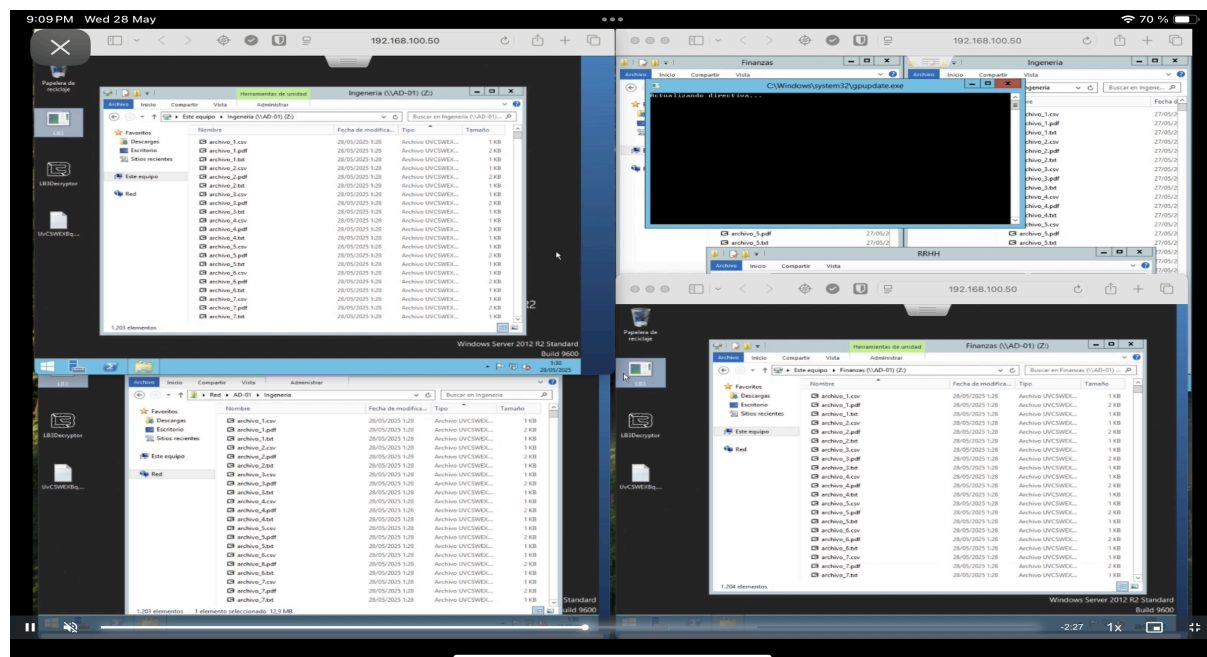
Una vez el ransomware activo la persona en turno encargada se percató del ataque y esta lo reporta de manera inmediata a sus superiores, para que este informe y de la alerta en nivel empresa, este delega funciones para analizar la mayor cantidad de información en el menor tiempo posible.



A la 1:28 Am el ransomware empezó a encriptar todos los archivos en todos los computadores y el servidor a los que estos estaban conectados bajo carpetas compartidas en la red de la empresa, en todos apareció un archivo .TXT el cual contenía instrucciones

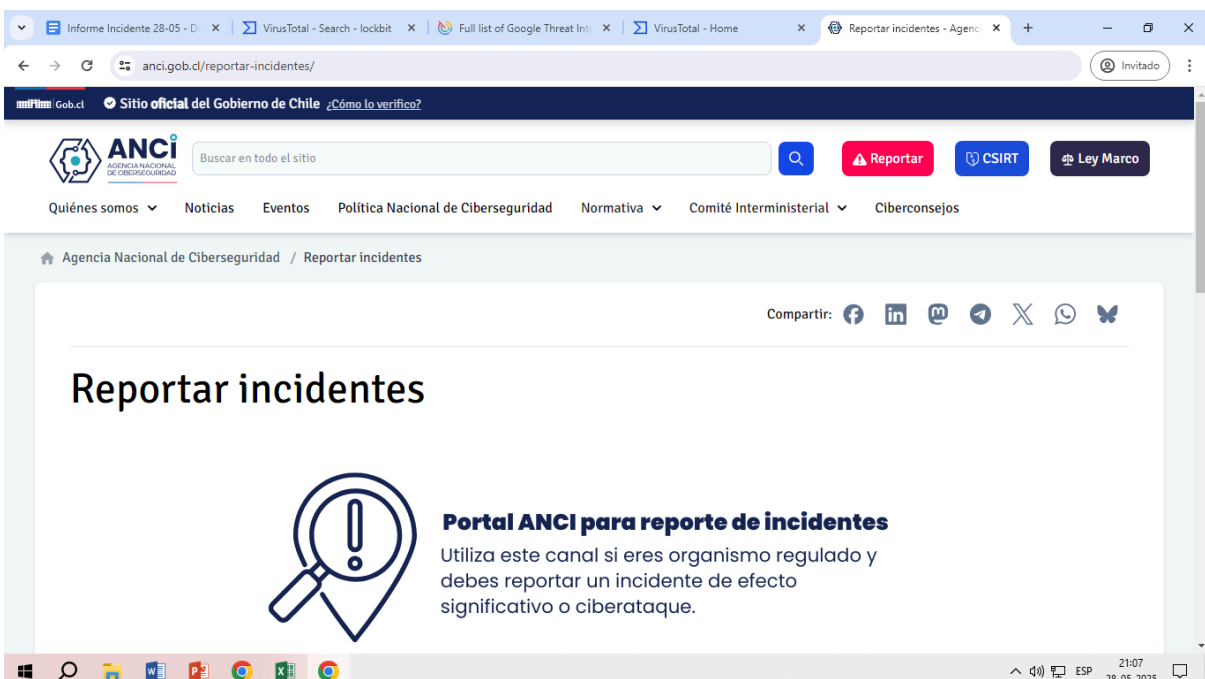
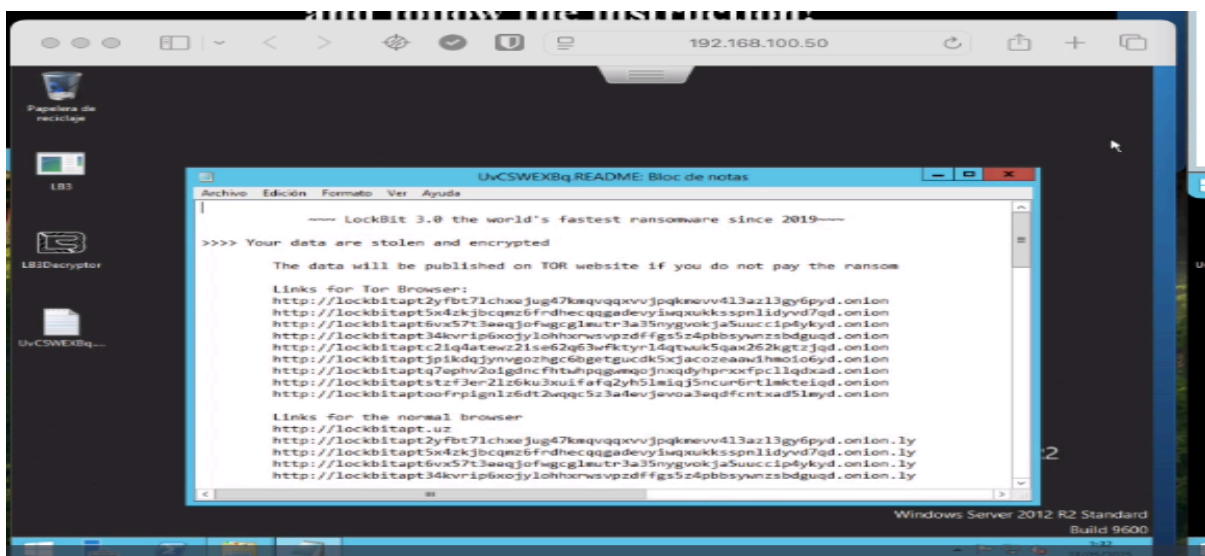


A la 1:30 Am el ransomware abre la consola de comandos del servidor la cual muestra el mensaje “Actualizando directiva...”

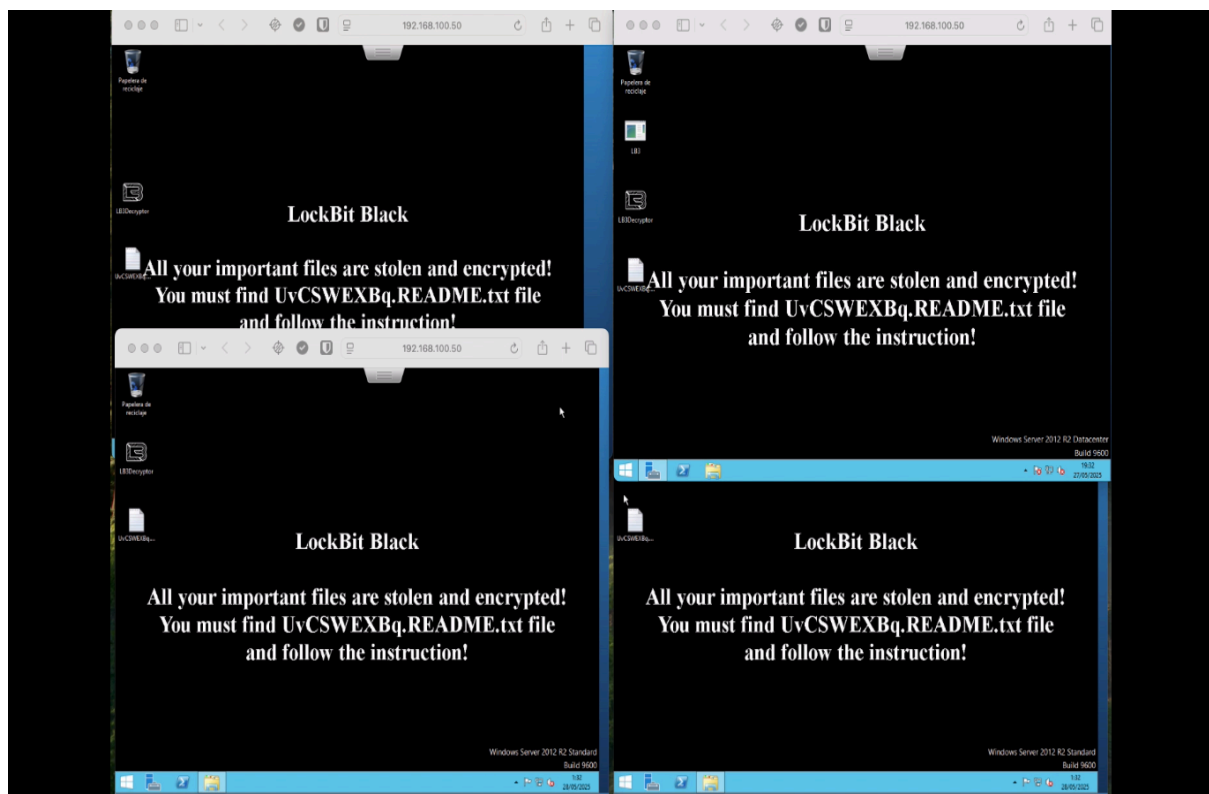


A las 1:31 Am todos los documentos han sido encriptados y se abre el archivo .TXT que apareció las cuales son instrucciones que indican que la información fue secuestrada y esta será publicada para su uso, para que esta pueda ser recuperada y no publicada o vendida se debe pagar un rescate con los links de cómo se debe realizar el pago

debido a la gravedad del asunto se reporta de inmediato el ataque a la ANCI en la página Anci.gob.cl



1:32 Am los computadores aparece un mensaje como fondo de pantalla con el nombre “LockBit Black” en todos los ordenadores con instrucciones de abrir el .TXT para obtener la información.



Plan preventivo ante futuros ataques

- Realizaremos una reunión con los equipos afectados para ver el paso a paso de la infección y ver los hechos.
- Se comprobarán todos los equipos y se actualizarán los antivirus.
- Trabajos de concientización y capacitaciones a cada departamento
- Realizaremos controles de phishing éticos

Agrega encabezados (Formato > Estilos de párrafo) y aparecerán en el índice.

-
- mejoraremos los controles de accesos verificando los privilegios.
- se cambiarán todas las claves de accesos de forma preventiva
- mejoramiento de respaldos de la información cada tres días para así tener un impacto reducido y controlado.

Aplicación ISO 27001

En cuanto a la ISO 27001, se pueden identificar los siguientes puntos a mejorar en caso de una posible reincidencia.

A8 Gestión de Activos

A8.1 Responsabilidad sobre los Activos

1. ¿Se ha realizado un inventario de activos que dan soporte al negocio y de Información?
2. ¿Se ha identificado al responsable de cada activo en cuanto a su seguridad?
3. ¿Se han establecido normas para el uso de activos en relación a su seguridad?
4. ¿Existe un procedimiento para la devolución de activos cedidos a terceras partes o a la finalización de un puesto de trabajo o contrato?

A8.2 Clasificación de la Información

1. ¿Se clasifica la información según su confidencialidad o su importancia en orden a establecer medidas de seguridad específicas?
2. ¿Los activos de información son fácilmente identificables en cuanto a su grado de confidencialidad o su nivel de clasificación?
3. ¿Existen procedimientos para el manipulado de la información de acuerdo a su clasificación?

A11 Seguridad Física y del Entorno

A11.1 Áreas de Seguridad

1. ¿Se establecen perímetros de seguridad física donde sea necesario con barreras de acceso?
2. ¿Existen controles de acceso a personas autorizadas en áreas restringidas?
3. ¿Se controla o supervisa la actividad de personal que accede a áreas seguras?

A11.2 Seguridad de los equipos

1. ¿Se protegen los equipos tanto del medio ambiente como de accesos no autorizados?
2. ¿Se protegen los equipos contra fallos de suministro de energía?
3. ¿Existen protecciones para los cableados de energía y de datos?
4. ¿Se planifican y realizan tareas de mantenimiento sobre los equipos?
5. ¿Se controlan y autorizan la salida de equipos, aplicaciones etc. que puedan contener información?
6. ¿Se consideran medidas de protección específicas para equipos que se utilicen fuera de las instalaciones de la propia empresa?
7. ¿Se establecen protocolos para proteger o eliminar información de equipos que causen baja o van a ser reutilizados?
8. ¿Se establecen normas para proteger la información de equipos cuando los usuarios abandonan el puesto de trabajo?
9. ¿Se establecen reglas de comportamiento para abandonos momentáneos o temporales del puesto de trabajo?

A12 Seguridad en las Operaciones

A12.1 Procedimientos y responsabilidades

1. ¿Se documentan los procedimientos y se establecen responsabilidades?
2. ¿Se controla que la información sobre procedimientos se mantenga actualizada?
3. ¿Se dispone de un procedimiento para evaluar el impacto en la seguridad de la información ante cambios en los procedimientos?
4. ¿Se controla el uso de los recursos en cuanto al rendimiento y capacidad de los sistemas?
5. ¿Los entornos de desarrollo y pruebas están convenientemente separados de los entornos de producción?

A12.2 Protección contra software malicioso

1. ¿Existen sistemas de detección para Software malicioso o malware?

A12.3 Copias de Seguridad

1. ¿Se ha establecido un sistema de copias de seguridad acordes con las necesidades de la información y de los sistemas?

A12.4 Registro y Supervisión

1. ¿Se realiza un registro de eventos?
 - Intentos de acceso fallidos/exitosos
 - Desconexiones del sistema
 - Alertas de fallos Etc.
2. ¿Se ha establecido un sistema de protección para los registros mediante segregación de tareas o copias de seguridad?
3. ¿Se protege convenientemente y de forma específica los accesos o los de los administradores?
4. ¿Existe un control de sincronización de los distintos sistemas?

A12.5 Control del Software

1. ¿Las instalaciones de nuevas aplicaciones SW o modificaciones son verificadas en entornos de prueba y existen protocolos de seguridad para su instalación?

A12.6 Vulnerabilidad Crítica

1. ¿Se establecen métodos de control para vulnerabilidades técnicas "hacking ético" etc.?
2. ¿Se establecen medidas restrictivas para la instalación de Software en cuanto a personal autorizado evitando las instalaciones por parte de usuarios finales?

A13 Seguridad en las comunicaciones

A13.1 Seguridad de redes

1. ¿En el entorno de red se gestiona la protección de los sistemas mediante controles de red y de elementos conectados?
2. ¿Se establecen condiciones de seguridad en los servicios de red tanto propios como subcontratados?
3. ¿Existe separación o segregación de redes tomando en cuenta condiciones de seguridad y clasificación de activos?

A16 Gestión de Incidentes de seguridad de la información

A16.1 Gestión de incidentes de seguridad de la información y mejoras

1. ¿Se definen responsabilidades y procedimientos para responder a los incidentes de la Seguridad de la Información?
2. ¿Se han implementado canales adecuados para la comunicación de incidentes en la seguridad de la Información?
3. ¿Se promueve y se han establecido canales para comunicar o identificar puntos débiles en la Seguridad de la Información?
4. ¿Se ha establecido un proceso para gestionar los incidentes en la Seguridad de la Información?
5. ¿Existen mecanismos para dar respuesta a los eventos de la Seguridad de la Información?
6. ¿La información que proporcionada por los eventos en la Seguridad de la información son tratados para tomar medidas preventivas?
7. ¿Existe un proceso para recopilar evidencias sobre los incidentes en la seguridad de la Información?

A17 Continuidad del negocio

A17.1 Continuidad de la seguridad de la información.

1. ¿Se ha elaborado un plan de continuidad del negocio ante incidentes de Seguridad de la Información?
2. ¿Se han implementado las medidas de recuperación previstas en el plan de Continuidad del Negocio?
3. ¿Se han verificado o probado las acciones previstas en el plan de Continuidad del Negocio?

Bibliografía

VirusTotal: <https://www.virustotal.com/gui/home/upload>

ISO27001: <https://www.normaiso27001.es/>

ChatGPT: <https://openai.com/es-ES/>

ANCI: <https://anci.gob.cl/reportar-incidentes/>